

华南理工大学本科生期末考试

2021-2022-1 学期《信息安全导论》B 卷

- 注意事项：1. 开考前请将密封线内各项信息填写清楚；
2. 所有答案请直接答在答题纸上；
3. 考试形式：闭卷；
4. 本试卷共四大题，满分 100 分，考试时间 120 分钟。

I、填空题：共 10 个空格，每个空格 1 分，共 10 分

1. 按照密钥类型分类，现代密码学分为：(1)和公钥密码学（非对称密码学）。
2. 信息保障是一个完整的动态过程，主要包含四个子过程，分别是：(2)、(3)、(4)、恢复(Restore)。
3. 密码学(Cryptography)包括(5)和(6)两部分，前者将密码变化的客观规律应用于密码的编制，后者研究密码变化规律中的固有缺陷，应用于破译密码以获取通信情报。
4. 自主访问控制(DAC)模式中，访问权限信息主要以三种形式存储，分别为：(7)、(8)、访问控制矩阵(ACM)。
5. 防火墙的主要功能是隔离(9)与(10)，控制和过滤两者之间的网络流量。

II、选择题：共 20 题，每题 2 分，共 40 分

1. DES 加密算法的分组长度、有效密钥长度分别为____和____。
A. 64, 56
B. 128, 56
C. 64, 64
D. 128, 64
2. 公钥密码提出的标志性事件是____的提出。
A. RSA 算法
B. Diffie-Hellman 密钥交换算法
C. ElGamal 算法
D. Rabin 算法
3. 公钥密码的通信安全性取决于：____
A. 数学难题
B. 私钥的保密性
C. 加密算法
D. 公钥的保密性
4. 在保证密码安全中，应采取的措施中不正确的是（）
A. 不用生日做密码
B. 不要使用少于 8 位的密码
C. 密码保存到邮箱中
D. 使用 U-key 双因子认证
5. 通常情况下，一次数字签名涉及到的信息不包括：____
A. 散列函数
B. 发送者公钥
C. 发送者私钥
D. 接收者私钥
6. 基于 Needham-Schroeder 认证协议不正确的说法是：

- A. 基于对称密钥的 Needham-Schroeder 认证协议需要一个可信的第三方作为认证服务器;
 B. 每一个使用者需要与认证服务器共享一个对称密钥;
 C. Needham-Schroeder 认证协议虽然设计比较严密, 但也存在漏洞, 容易导致重放攻击;
 D. Needham-Schroeder 认证协议不能基于公开密钥实现。
7. 病毒的发展阶段包括: _____。
- A. 潜伏、感染、触发、破坏
 B. 潜伏、感染、破坏
 C. 感染、触发、破坏
 D. 潜伏、感染、触发
8. 以下关于特洛伊木马的说法, 下列说法正确的是_____。
- A. 能够进行自我复制
 B. 是依赖于宿主程序的
 C. 木马没有自启动功能
 D. 可以通过将木马图标修改成图像文件图标的方式隐藏自己
9. Bell-LaPadula 模型与 Biba 模型的主要区别在于 Bell-LaPadula 模型具有只允许_____的特点, 可以有效保护_____。
- A. 向下读、向上写, 机密性
 B. 向上读、向下写, 机密性
 C. 向下读、向上写, 完整性
 D. 向上读、向下写, 完整性
10. 数字签名不能保证的是: _____。
- A. 接收到的消息无伪造
 B. 接收到的消息无篡改
 C. 接收到的消息无错误
 D. 接收到的消息无泄密
11. 关于 Windows 系统的访问控制模块的正确的说法是: _____。
- A. Windows 中的每个账户或账户组都配有一个安全描述符 (Security Descriptor);
 B. Windows 中的每个被访问的客体对象都有一个访问令牌 (Access Token);
 C. 安全描述符包含了访问控制列表 (ACL);
 D. 改变账户权限时, 用户不需要注销后重新登录。
12. 以下哪一项不属于防火墙的功能: _____。
- A. 网络流量过滤
 B. 网络监控审计
 C. 支持 NAT 部署
 D. 防范内部攻击
13. 以下各项中不属于消息摘要算法的是: _____。
- A. MD5
 B. SHA-1
 C. ElGamal
 D. SHA-256
14. 当服务器运行速度明显减慢, 且打开任务管理器后发现 CPU 的使用率达到了百分之百, 此时最有可能受到了哪一种攻击? ()
- A. 特洛伊木马
 B. 拒绝服务 (DoS)
 C. 欺骗
 D. 中间人攻击
15. 在 PKI 中, 不属于 CA 功能的是: _____

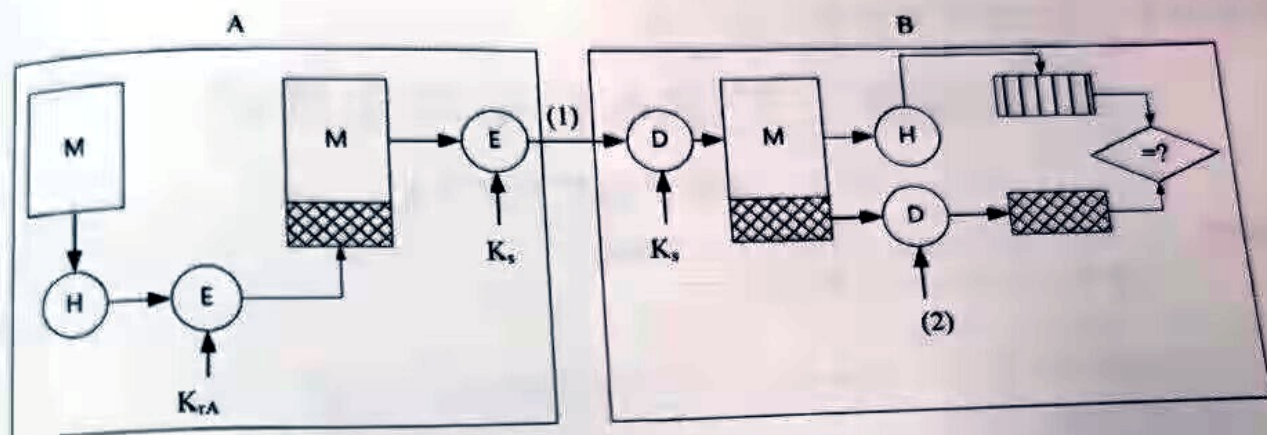
- A. 审批证书 B. 颁发证书 C. 加密证书 D. 备份证书
16. 以下关于“挑战-应答”认证的正确表述是：_____。
- A. “挑战-应答”只能用于单方向的身份认证；
 B. “挑战-应答”机制不能抵御重放攻击；
 C. 完成“挑战-应答”需要借助第三方服务器；
 D. 在双方通信过程中，“挑战-应答”机制可以反复多次使用。
17. 以下不会导致 PKI 撤销数字证书的是：_____。
- A. 密钥泄露 B. 系统升级
 C. 证书到期 D. 用户身份（从属）变更
18. 识别用户身份的认证数据不断动态变化，每次认证使用不同的认证数据，这类认证称为：_____。
- A. 静态数据认证 B. 动态数据认证
 C. 口令认证 D. 生物特征认证
19. RBAC 在体系结构上具有许多优势，使其更加灵活、方便和安全，主要体现在：
- A. RBAC 中的用户能够自主地将访问权限授予别的用户；
 B. RBAC 中能够实现多级别安全需求；
 C. RBAC 中的角色可以由用户根据需求进行定义和分配；
 D. RBAC 中的用户通过饰演不同的角色获得角色所拥有的访问许可权。
20. 下面选项中，需要寄生在宿主文件中的恶意软件是_____。
- A. 病毒、后门 B. 蠕虫、后门
 C. 病毒、蠕虫 D. 病毒、蠕虫、后门

III、简答题：共 4 题，每题 5 分，共 20 分

1. 现代密码体制与古代加密方法在安全性保障的思路和方法上有何不同？
2. 简述 PKI 的组成结构及各部分的主要功能。
3. 病毒包含哪几个模块？简要介绍每个模块的功能。
4. 信息安全的三个基本目标（CIA 三元组）分别是什么？

IV、综合题：共 3 题，每题 10 分，共 30 分

1. 自主访问控制（DAC）与强制访问控制（MAC）这两种访问控制机制的原理分别是什么？其优缺点分别是什么？并解释 MAC 的四种策略。
2. 如下图所示为 A、B 双方的保密通信模型，其中 M 代表明文，H 代表散列函数，E 和 D 分别表示加密和解密环节， K_A 和 K_s 分别为 A 的私钥与 A 与 B 的会话密钥。试回答：图中（1）和（2）分别应该填什么内容（给出说明及表达式）？该通信模型实现了哪些信息安全目标？A 侧的 H 和 E 环节能否互换？如果不能互换请说明原因；如果能互换请说明对安全目标的影响。（注意：这里的用私钥加密，也指的是签名，其含义相同）



3. 什么是身份认证？假设 A 是示证方，CA 是证书颁发中心，B 是验证方，请画出基于数字证书的身份认证过程中的三方交互示意图，标出每一步骤的序号，并注明每一步实现的功能。